

2017-11-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

JUGGLING ACT: FIND OUT WHAT HAPPENED IN 6 PCAPS

Pcap 1 of 6: [2017-11-21-traffic-analysis-exercise-1-of-6.pcap.zip](#)

This is a pcap of Rig exploit kit (EK) sending Ramnit banking Trojan. Below is a screenshot of EmergingThreats alerts from Squil using Suricata in Security Onion. It shows the associated IP addresses and ports involved.

RealTime Events		Escalated Events							
ST	CNT		Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
ES	1		2017-11-20 23:07:53	192.168.55.193	49160	188.225.38.247	80	6	ET CURRENT_EVENTS RIG EK URI Struct Jun 13 2017
ES	1		2017-11-20 23:07:54	192.168.55.193	49160	188.225.38.247	80	6	ET CURRENT_EVENTS RIG EK URI Struct Jun 13 2017
ES	1		2017-11-20 23:07:56	192.168.55.193	49163	188.225.38.247	80	6	ET CURRENT_EVENTS RIG EK URI Struct Jun 13 2017
ES	1		2017-11-20 23:08:04	192.168.55.193	49165	194.87.110.230	443	6	ET TROJAN Win32/Ramnit Checkin
ES	1		2017-11-20 23:08:05	192.168.55.193	49165	194.87.110.230	443	6	ET TROJAN Win32/Ramnit Checkin
ES	1		2017-11-20 23:08:06	192.168.55.193	49166	217.20.116.142	443	6	ET TROJAN Win32/Ramnit Checkin
ES	1		2017-11-20 23:08:06	192.168.55.193	49167	217.20.116.142	443	6	ET TROJAN Win32/Ramnit Checkin
ES	1		2017-11-20 23:08:06	192.168.55.193	49168	194.87.110.230	443	6	ET TROJAN Win32/Ramnit Checkin
ES	1		2017-11-20 23:08:07	192.168.55.193	49168	194.87.110.230	443	6	ET TROJAN Win32/Ramnit Checkin
ES	1		2017-11-20 23:11:32	192.168.55.193	49175	194.87.110.230	443	6	ET TROJAN Win32/Ramnit Checkin
ES	1		2017-11-20 23:11:32	192.168.55.193	49175	194.87.110.230	443	6	ET TROJAN Win32/Ramnit Checkin
ES	1		2017-11-20 23:11:33	192.168.55.193	49177	194.87.110.230	443	6	ET TROJAN Win32/Ramnit Checkin
ES	1		2017-11-20 23:11:34	192.168.55.193	49177	194.87.110.230	443	6	ET TROJAN Win32/Ramnit Checkin

Pcap 2 of 6: [2017-11-21-traffic-analysis-exercise-2-of-6.pcap.zip](#)

This is a pcap of Loki Bot infection traffic. It probably came from an email delivered through Yahoo.com, because network traffic before the alerts shows a login to mail.yahoo.com when searching in Wireshark.

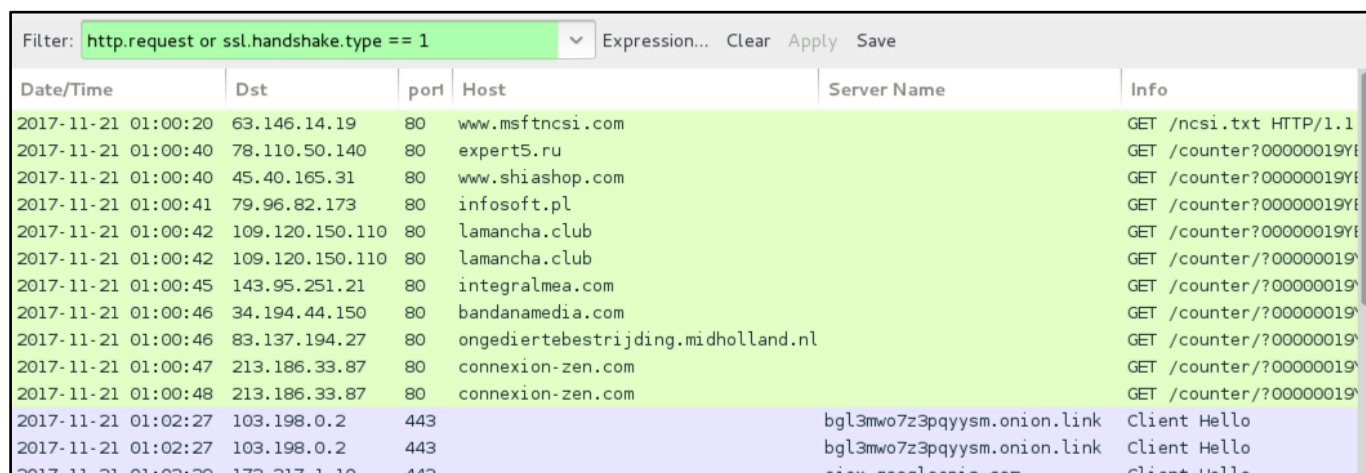
Filter: http.request or ssl.handshake.type == 1		Expression...		Clear	Apply	Save
Date/Time	Dst	port	Host	Server Name	Info	
2017-11-20 23:58:51	13.107.13.80	80	api.bing.com		GET /qsl.aspx?query=mail.yahoo.&maxwidth=32765&rowheight=	
2017-11-20 23:58:51	13.107.13.80	80	api.bing.com		GET /qsl.aspx?query=mail.yahoo.c&maxwidth=32765&rowheight	
2017-11-20 23:58:51	13.107.13.80	80	api.bing.com		GET /qsl.aspx?query=mail.yahoo.co&maxwidth=32765&rowheight	
2017-11-20 23:58:51	13.107.13.80	80	api.bing.com		GET /qsl.aspx?query=mail.yahoo.com&maxwidth=32765&rowheight	
2017-11-20 23:58:52	69.147.64.34	443		mail.yahoo.com	Client Hello	
2017-11-20 23:58:52	69.147.64.34	443		mail.yahoo.com	Client Hello	
2017-11-20 23:58:52	98.139.21.169	443		login.yahoo.com	Client Hello	
2017-11-20 23:58:52	98.139.21.169	443		login.yahoo.com	Client Hello	
2017-11-20 23:58:52	69.147.64.34	443		mail.yahoo.com	Client Hello	

Below is a screenshot of EmergingThreats (ET) and ET pro alerts from Squil using Suricata in Security Onion. It shows the associated IP addresses and ports involved.

2017-11-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

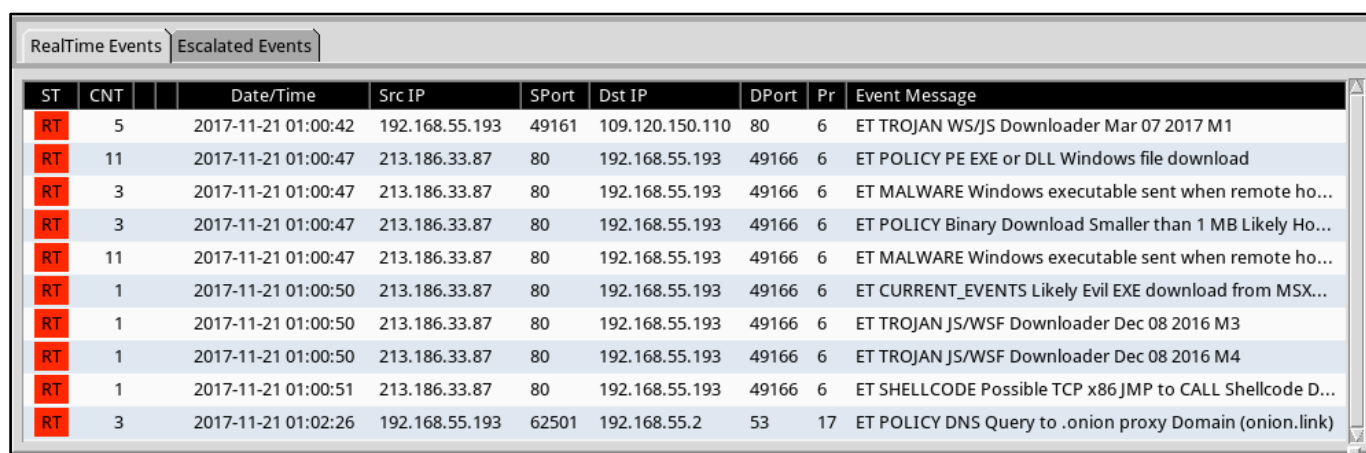
instructions. No indicators as to where this came from, but it was probably sent through an email or malspam.

Below is the traffic filtered in Wireshark, where you can see all of the HTTP request that start with **GET /counter?00000019Y...** We also see **bgl3mwo7z3pqyysm.onion** as a domain in the HTTPS traffic, which is associated with NemucodAES (see the previous link).



Date/Time	Dst	port	Host	Server Name	Info
2017-11-21 01:00:20	63.146.14.19	80	www.msftncsi.com		GET /ncsi.txt HTTP/1.1
2017-11-21 01:00:40	78.110.50.140	80	expert5.ru		GET /counter?00000019Y...
2017-11-21 01:00:40	45.40.165.31	80	www.shiashop.com		GET /counter?00000019Y...
2017-11-21 01:00:41	79.96.82.173	80	infosoftware.pl		GET /counter?00000019Y...
2017-11-21 01:00:42	109.120.150.110	80	lamancha.club		GET /counter?00000019Y...
2017-11-21 01:00:42	109.120.150.110	80	lamancha.club		GET /counter/?00000019Y...
2017-11-21 01:00:45	143.95.251.21	80	integralmea.com		GET /counter/?00000019Y...
2017-11-21 01:00:46	34.194.44.150	80	bandanamedia.com		GET /counter/?00000019Y...
2017-11-21 01:00:46	83.137.194.27	80	ongediertebestrijding.midholland.nl		GET /counter/?00000019Y...
2017-11-21 01:00:47	213.186.33.87	80	connexion-zen.com		GET /counter/?00000019Y...
2017-11-21 01:00:48	213.186.33.87	80	connexion-zen.com		GET /counter/?00000019Y...
2017-11-21 01:02:27	103.198.0.2	443		bgl3mwo7z3pqyysm.onion.link	Client Hello
2017-11-21 01:02:27	103.198.0.2	443		bgl3mwo7z3pqyysm.onion.link	Client Hello
2017-11-21 01:02:28	172.217.1.10	443		ajax.googleapis.com	Client Hello

Below are the EmergingThreats alerts I saw on this traffic from Squil using Suricata in Security Onion.



ST	CNT	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	5	2017-11-21 01:00:42	192.168.55.193	49161	109.120.150.110	80	6	ET TROJAN WS/JS Downloader Mar 07 2017 M1
RT	11	2017-11-21 01:00:47	213.186.33.87	80	192.168.55.193	49166	6	ET POLICY PE EXE or DLL Windows file download
RT	3	2017-11-21 01:00:47	213.186.33.87	80	192.168.55.193	49166	6	ET MALWARE Windows executable sent when remote ho...
RT	3	2017-11-21 01:00:47	213.186.33.87	80	192.168.55.193	49166	6	ET POLICY Binary Download Smaller than 1 MB Likely Ho...
RT	11	2017-11-21 01:00:47	213.186.33.87	80	192.168.55.193	49166	6	ET MALWARE Windows executable sent when remote ho...
RT	1	2017-11-21 01:00:50	213.186.33.87	80	192.168.55.193	49166	6	ET CURRENT_EVENTS Likely Evil EXE download from MSX...
RT	1	2017-11-21 01:00:50	213.186.33.87	80	192.168.55.193	49166	6	ET TROJAN JS/WSF Downloader Dec 08 2016 M3
RT	1	2017-11-21 01:00:50	213.186.33.87	80	192.168.55.193	49166	6	ET TROJAN JS/WSF Downloader Dec 08 2016 M4
RT	1	2017-11-21 01:00:51	213.186.33.87	80	192.168.55.193	49166	6	ET SHELLCODE Possible TCP x86 JMP to CALL Shellcode D...
RT	3	2017-11-21 01:02:26	192.168.55.193	62501	192.168.55.2	53	17	ET POLICY DNS Query to .onion proxy Domain (onion.link)

Pcap 5 of 6: [2017-11-21-traffic-analysis-exercise-5-of-6.pcap.zip](#)

This is the NetSupport Manager RAT sent as a fake Chrome Font update from HoeflerText popups by the EITest campaign. It's similar to what's shown [here](#) on 2017-12-12.

www.accutech.net is the compromised site, and **www.liceobelgrano.edu.ar/goto3.php** is the URL that returned **Font_Chrome.exe** as shown in the image below.

2017-11-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Filter: tcp.stream eq 11

Date/Time	Dst	port	Host	Info
2017-11-21 01:22:50	212.1.208.53	80	www.liceobelgrano.edu.ar	GET /goto3.php HTTP/1.1

Follow TCP Stream (tcp.stream eq 11)

Stream Content

```
GET /goto3.php HTTP/1.1
Host: www.liceobelgrano.edu.ar
Connection: keep-alive
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 6.1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/62.0.3202.94 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8
Referer: http://www.accutech.net/
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9

HTTP/1.1 200 OK
Date: Tue, 21 Nov 2017 01:22:51 GMT
Server: Apache
X-Powered-By: PHP/5.3.29
Accept-Ranges: bytes
Content-Disposition: attachment; filename=Font_Chrome.exe
Upgrade: h2
Connection: Upgrade, Keep-Alive
Content-Length: 225235
Keep-Alive: timeout=3, max=100
Content-Type: application/octet-stream

MZ.....@.....!..L!This program cannot be run in DOS mode.
$ + } on on on bn n wn 3 vn 3 l
```

Below is a screenshot of EmergingThreats (ET) and ET pro alerts from Squil using Suricata in Security Onion. It shows the associated IP addresses and ports involved. In it, you can see the **ETPRO CURRENT EVENTS Possible EITest SocEng Chrome Fonts** alert, and you can also see ETPRO alerts for **NetSupport Remote Admin Checkin** and **NetSupport Remote Admin Response**.

RealTime Events

Escalated Events

ST	CNT		Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	5		2017-11-21 01:22:52	212.1.208.53	80	192.168.55.194	49180	6	ET POLICY PE EXE or DLL Windows file download
RT	5		2017-11-21 01:22:52	212.1.208.53	80	192.168.55.194	49180	6	ET POLICY Binary Download Smaller than 1 MB Likely Hostile
RT	1		2017-11-21 01:25:56	212.1.208.53	80	192.168.55.194	49180	6	ETPRO CURRENT_EVENTS Possible EITest SocEng Chrome Fonts ...
RT	1		2017-11-21 01:28:13	192.168.55.194	49159	94.242.198.167	1488	6	ET POLICY HTTP Request on Unusual Port Possibly Hostile
RT	8		2017-11-21 01:28:13	192.168.55.194	49159	94.242.198.167	1488	6	ET POLICY HTTP POST on unusual Port Possibly Hostile
RT	8		2017-11-21 01:28:13	192.168.55.194	49159	94.242.198.167	1488	6	ETPRO POLICY NetSupport Remote Admin Checkin
RT	3		2017-11-21 01:28:13	94.242.198.167	1488	192.168.55.194	49159	6	ETPRO POLICY NetSupport Remote Admin Response
RT	1		2017-11-21 01:28:13	192.168.55.194	49159	94.242.198.167	1488	6	ETPRO TROJAN Backdoor.Ratenjay POST with System Information

Pcap 6 of 6: [2017-11-21-traffic-analysis-exercise-6-of-6.pcap.zip](#)

This pcap has Emotet traffic. It's similar to what's discussed in [this ISC diary](#) from November 2017. So it likely came from malspam. Below is a screenshot of EmergingThreats (ET) and ET pro alerts from Squil using Suricata in Security Onion.

2017-11-21 TRAFFIC ANALYSIS EXERCISE: ANSWERS

RealTime Events

Escalated Events

ST	CNT		Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	1		2017-11-21 02:00:33	192.168.55.186	49759	194.88.246.242	443	6	ET CNC Feodo Tracker Reported CnC Server grou...
RT	3		2017-11-21 02:00:33	192.168.55.186	49759	194.88.246.242	443	6	ET POLICY HTTP Request on Unusual Port Possibl...
RT	3		2017-11-21 02:00:33	192.168.55.186	49759	194.88.246.242	443	6	ET POLICY HTTP POST on unusual Port Possibly ...
RT	3		2017-11-21 02:00:33	192.168.55.186	49759	194.88.246.242	443	6	ETPRO TROJAN W32/Emotet.v4 Checkin
RT	3		2017-11-21 02:00:33	192.168.55.186	49759	194.88.246.242	443	6	ETPRO TROJAN W32/Emotet.v4 Checkin 2
RT	3		2017-11-21 02:00:33	192.168.55.186	49759	194.88.246.242	443	6	ETPRO TROJAN W32/Emotet.v4 Checkin 3
RT	3		2017-11-21 02:00:33	192.168.55.186	49759	194.88.246.242	443	6	ET POLICY HTTP traffic on port 443 (POST)
RT	3		2017-11-21 02:00:33	192.168.55.186	49759	194.88.246.242	443	6	ET INFO GENERIC SUSPICIOUS POST to Dotted Q...
RT	2		2017-11-21 02:03:24	194.88.246.242	443	192.168.55.186	49759	6	ETPRO TROJAN Emotet Post Drop C2 Comms M2
RT	2		2017-11-21 02:03:24	194.88.246.242	443	192.168.55.186	49759	6	ETPRO TROJAN W32/Emotet.v4 Checkin Fake 404 ...
RT	1		2017-11-21 02:15:54	194.88.246.242	443	192.168.55.186	50002	6	ETPRO TROJAN Emotet Post Drop C2 Comms

Below is a TCP stream from 194.88.246.242 with traffic that triggered the Emotet alerts above.

Filter: tcp.stream eq 53

Expression... Clear Apply Save Filter Filter Filter Filter Filter

Date/Time	Dst	port	Host	Info
2017-11-21 02:00:33	194.88.246.242	443		49759->https [SYN] Seq=0 Win=65535 Len=0 MSS=1460 WS=8 SAC

Follow TCP Stream (tcp.stream eq 53)

Stream Content

```
POST / HTTP/1.1
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 10.0; WOW64; Trident/7.0; .NET4.0C; .NET4.0E)
Host: 194.88.246.242
Content-Length: 484
Connection: Keep-Alive
Cache-Control: no-cache

...jq1+.b...SDZ.p=,.....*"...C.i8+g.."..pz5...<..F..k.....<.CQ...b.hc.....y..4Pd..B?ca....\..bL.Cc?G%4t.-
v...3.C...T.....Z..
..
.^.....b.U..c...*/.....Z.`3..
Q.gXvG;_i.\..~K.b....jo....
.2rX.."..IL..9..=.\I.ki..cTU.1..Jb.7.....Kb(.a..a)...
.....[..._G.E.....^.....O..T..<4q.'GV.._::...../;..B..Y....Y..~!.C.rY.....>.....M...A...eYnce..|.....f...
.@p...
.F..M...s]..2..0/H.....!.....@.j.-Tc..`<bg?i.....y.s.....^f{.....*.....(.....*.....*.....up
;p.BV.Q..<./[.s[29581 bytes missing in capture file].....z+
$. .S.N...P...:.....vz.....Z.w.....`Bu...../7.....rMt\.;.^ @..)%
B....z.S.C.~...}-;..s..l...y.dj..|..b...n.*c../>.....
.y~.o...../...a.Z.%|f_Ta.@..A..$.m.....vL.....rx..RgR....;
$.~8~q)....._i...m.m.n.<.jM.....^.....M.F.k.....^hV....}
W..O..q#a.....^Ib...F..._x.....r.B8.}-V[X&.6.....>"Q....r.&.....$.G_.4W...x.7L....Lgk..V.-.J..z.....
..+o.....f*DN.[.k..@q.....x.....D.D..hY.f.....8.#.....l.....6...u8...&tN.....H...HoFv..P.....c...:'q...H..)
$.~.....UL;`~
...XZn*...&..q..K..q>.t..f7.]../.T.Fg.SG.;
```